Domain 3: Security Architecture and Engineering

- **Cryptographic**
  - Cryptography is the science of secret writing that enables an entity to store transmit data, and process in a form that is only available to an intended recipient
- Cryptography works with **XOR binary** function
  - If both bits are the same the result is Zero
  - If they are different the result is One
- Type of Cryptography
  - **Modern**
    - Symmetric/Shared key /Private
    - Asymmetric
  - **Classical**
    - Transposition
    - Substitution
- Cryptography today can be said to provide some important security services. The five key services that cryptography can provide are the following:
  - **Confidentiality**
    - Confidentiality is a service that ensures keeping information secret from those who are not authorized to have it.
  - **Integrity**
    - Cryptography tools cannot prevent a message from being altered, but they can be effective to detect either intentional or accidental modification of the message.
  - **Authenticity**
    - Authenticity can allow a recipient to know positively that transmission of information came from the entity that we expect it from.
    - Sometimes referred to as **"proof of origin"**.
  - **Non-Repudiation**
    - This is a service that prevents an entity from denying having participated in a previous action.
    - Non-repudiation of origin means that the sender cannot deny they sent a particular message.
    - Non-repudiation can only be achieved properly through the use of digital signatures.
  - **Access Control**
    - Access would only be possible for those individuals who had access to the correct cryptographic keys.

- **NOTE:-**
  a. **Confidentiality** is normally achieved by **encrypting the message content**,
  b. **Data integrity** is achieved through **cryptographic hashing functions,**
  c. **authenticity** is achieved through the use of **asymmetric cryptography**,
  d. **non-repudiation** is normally achieved through the use of cryptographic **digital signatures**, and
  e. **access control** can be achieved through both symmetric and asymmetric key cryptography but encrypting with keys that allow the recipient to decrypt with the proper keys.

- Key Encryption Concepts and Definitions
  - Plaintext (Cleartext) -- Human readable text
  - **Null Cipher**
    - Removes the values to hide the identity.
    - Null cipher option may be used in cases where the use of encryption is not necessary but yet the fact that no encryption is needed must be configured for the system to work.
  - **Algorithm**
    - A cryptographic algorithm is a mathematically complex modern cipher
    - Algorithm or Cipher is the mathematical computation, function, and calculation used to encrypt and decrypt
  - **Key/Crypto variable**
    - Secret value used with an algorithm
    - The key dictates what parts of the algorithm will be used, in what order, and with what values
  - **Key Space**
    - Number of possible key combinations
    - e.g. 256-bit = 2256 = 1.1578 x 1077 possible keys
  - **Key Stretching**
    - The initial key is fed into an algorithm that outputs an enhanced (stronger) key.
  - **Symmetric**
    - Using a single key
  - **Asymmetric**
    - Using two mathematically related keys (public/private)
  - **Public Key**
    - Key that is publicly distributed
  - **Private key**
    - Corresponding key that is secured by the owner.
  - **Block Cipher**
    - Divide the data into blocks, then encrypt using the same key.
    - The block contains both the data & IV, IV is dependent upon the algorithm you are using.
    - Block size also varies according to the algorithm.
  - **Stream Cipher**
    - Perform entire streaming, size of the stream is 128, the key size is 64, the same key will be repeated for XOR function
  - **Initialization vector (IV):**
    - A non-secret binary vector is used as the initializing input algorithm for the encryption of a plaintext block sequence to increase security by introducing additional cryptographic variance and synchronizing cryptographic equipment.
  - **Cryptography**
    - Science of hiding meaning of communication.
  - **Cryptanalysis**
    - Science of studying and breaking the secrecy of encryption algorithms and their necessary pieces.
  - **Cryptosystem**
    - Mechanism that carries out the encryption process.

- **OTP- One Time Pad**
  - Running key Cipher
  - Whatever the size of the data we have, the same one-time pad is used XOR then use the key to encrypt the data.
  - Devised by Gilbert Vernam in 1917.
  - Unbreakable
  - Uses a random OTP which is at least as long as the message.
    - **Exam Tip - What is Vernam Cipher - OTP**
      Which cryptography is impossible to crack - OTP
      Use for sensitive data - OTP

  - In addition to choosing keys that are long and will remain secure for the expected length of time that the information will remain confidential, you should also implement some other key management practices:
    ■■ Always store secret keys securely and, if you must transmit them over a network, do so in a manner that protects them from unauthorized disclosure.
    ■■ Select keys using an approach that has as much randomness as possible, taking advantage of the entire key space.
    ■■ Destroy keys securely when they are no longer needed.

- **Type of Cryptographic**
  - There are three primary types of modern encryption

    Symmetric
    - Symmetric encryption uses one key: the same key encrypts and decrypts.

    Asymmetric
    - Asymmetric cryptography uses two keys: if you encrypt with one key, you may decrypt with the other

    Hashing
    - Hashing is a one-way cryptographic transformation using an algorithm (and no key).

- **Symmetric Cryptography**
  - Symmetric encryption uses one key to encrypt and decrypt
  - Symmetric encryption is also called “Secret key” encryption: the key must be kept secret from third parties.
  - Strengths include speed and cryptographic strength per bit of key.
  - The major weakness is that the key must be securely shared before two parties may communicate securely.
  - Symmetric keys are often shared via an out-of-band method and face-to-face discussion.

- **Advantage**
  - Fast, Secure, Confidentiality
  - major strength of symmetric key cryptography is the great speed
- **Disadvantage**
  - Key management is difficult

- Not able to provide non-repudiation of origin, access control, & digital signatures.
- Requires both sender & receiver to share the same key.
- The algorithm is not scalable

- Symmetric encryption may have **Stream and Block Ciphers** modes.
  - Stream Modes means each bit is independently encrypted in a Stream.
  - Block mode ciphers encrypt blocks of data each round:
    - 64 bits for the Data Encryption Standard (DES)
    - 128 bits for AES
    - Key Formula (must be remember)

$$\text{Number of Keys} = \frac{n(n-1)}{2}$$

- **Initialization Vectors**
  - Initialization Vectors (IV)
    - Initialization vector is used in some symmetric ciphers to ensure that the **first encrypted block of data is random**. This ensures that identical plaintexts encrypt to different ciphertexts.
- **Modes Of Block Cipher**
  - A block-based cipher is subject to the problems of latency, or delay, in processing
  - **Data Encryption Standard (DES)**
    - DES Developed by IBM, key size 64 bit, effective key size is 56 bit (8-bit parity value) block size is also 64.
    - Performs 16 rounds of operations (XOR).
      - Mode of DES
        - Electronic Code Book (ECB)
        - Cipher Block Chaining (CBC)
        - Cipher Feedback (CFB)
        - Output Feedback (OFB)
        - Counter (CTR) Mode
    - Electronic Code Book (ECB)
      - The simplest of the encryption modes is the **electronic codebook** (ECB) mode

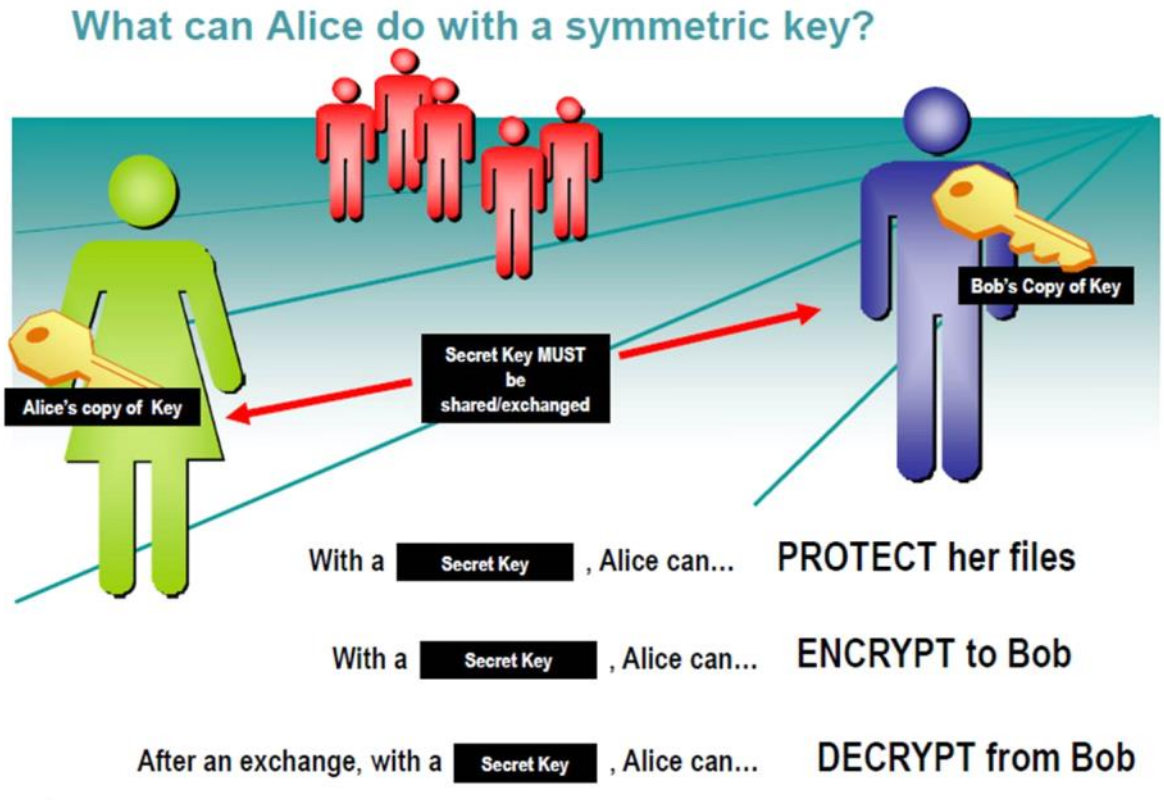
Basic Block Cipher Modes

Mode	Usage
Electronic Code Book (ECB)	Very Short Messages (Less than 64 bits in length) such as the transmission of a DES Key
Cipher Block Chaining (CBC)	Authentication
Cipher Feedback (CFB)	Authentication

Output Feedback (OFB)	Authentication
Counter (CTR)	Used in high-speed applications such as IPSEC and ATM

- **Double DES**
  - Double DES is an encryption technique that uses two instances of DES on same plain text
  - Double DES overall key size is 64*2, Effective key size 56*2
  - The primary complaint about DES was that key is too short.
  - **2DES multiply - key size (64x2), effective key size (56x2 = 112bit), and round of operations (16x2)**
  - Double DES is vulnerable for **Meet-in-the-Middle Attack (MITM)**
  - Meet-in-the-Middle Attack (MITM) the objective is to find the key.

- **Triple DES**
  - Triple DES is an encryption technique that uses three instances of DES on same plain text.
  - Triple DES overall key size is 64*3, Effective key size 56*3
  - **3DES triple - key size (64x3), effective key size (56x3 = 168bit) and round of operations (16x3)**
    - Effective rendered a key with a 168-bit Strength
      - Encrypts message three times with Multiple Keys
        - DES-EEE3 uses three keys for encryption
        - DES-EDE3 uses 3 keys , encrypts ,decrypts & encrypts data
        - DES-EEE2, DES-EDE2 is the same as the previous mode, but the first and third operation uses the same key.
- **Remember for the exam SSL (DES) TLS (AES)**



Difference between AES & DES (IMP EXAM POINT)

AES	DES
AES stands for Advanced Encryption Standard	DES stands for Data Encryption Standard
Key length can be 128-bits, 192-bits, and 256-bits.	Key length is 56 bits in DES. (Effective)
Number of rounds depends on key length: 10(128-bits), 12(192-bits), or 14(256-bits)	DES involves 16 rounds of identical operations
The structure is based on a substitution-permutation network.	The structure is based on Feistel network.
AES is more secure than the DES cipher and is the de facto world standard.	DES can be broken easily as it has known vulnerabilities. 3DES(Triple DES) is a variation of DES which is secure than the usual DES.
The rounds in AES are: Byte Substitution, Shift Row, Mix Column, and Key Addition	The rounds in DES are: Expansion, XOR operation with round key, Substitution, and Permutation
AES can encrypt 128 bits of plaintext.	DES can encrypt 64 bits of plaintext.
AES cipher is derived from the square cipher.	DES cipher is derived from Lucifer cipher.
AES was designed by Vincent Rijmen and Joan Daemen.	DES was designed by IBM.
No known crypt-analytical attacks against AES but side-channel attacks against AES implementations possible. Biclique attacks have better complexity than brute-force but still ineffective.	Known attacks against DES include Brute-force, Linear crypt-analysis, and Differential crypt-analysis.
AES is Secure & requires limited computation	DES not Secure than AES & requires limited computation
Used in Software Encryption	Used in Hardware Encryption

Symmetric Algorithms

Strength	Name	Key Size
Weak	RC2 -40	40
	DES	56
	RC5-64/16/7	56
Medium	RC5-64/16/10	80
	Skipjack	80
Strong	RC2-128	128
	RC5-64/12/16	128
	IDEA	128
	Blowfish	128
	3DES	168
Very Strong	RC5-64/12/32	256

	Twofish	256
	RC6	256
	Rijndael	256

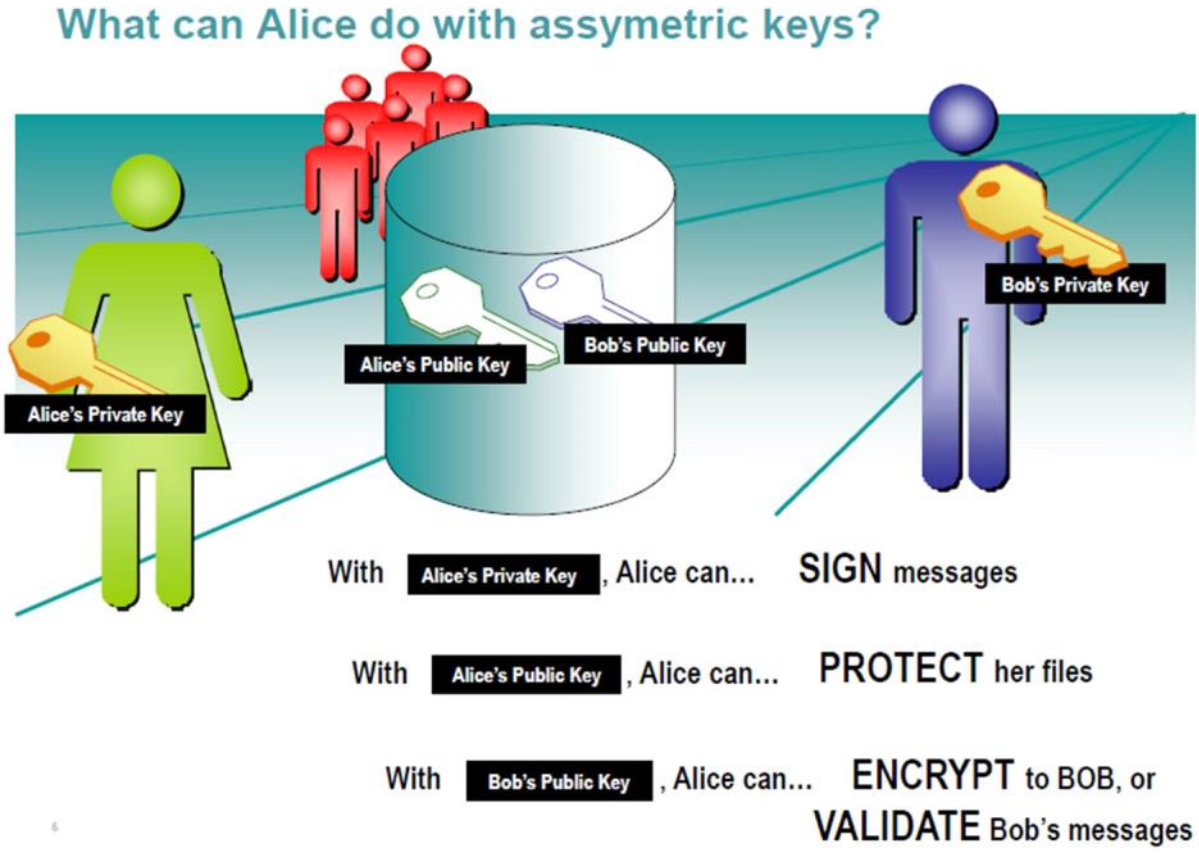
- **Advance Encryption Standard**
  - AES was created by the National Institute of Standards and Technology (NIST) in 2001 to replace DES
  - AES is based on the Rijndael cipher, which has low processing overhead and the ability to work with software in a variety of environments.
  - AES is a subset of the Rijndael block cipher[3] developed by two Belgian cryptographers, Vincent Rijmen and Joan Daemen, who submitted a proposal to NIST during the AES selection process.
  - Rijndael is a family of ciphers with different key and block sizes.
  - The Rijndael cipher supports key and block sizes of 128, 192, and **256 bits**, with various rounds of encryption based on the key and block size.
  - The design and strength of all key lengths of the AES algorithm (i.e., 128, 192, and 256) are sufficient to protect classified information up to the SECRET level.
  - TOP SECRET information will require use of either the 192 or 256 key lengths

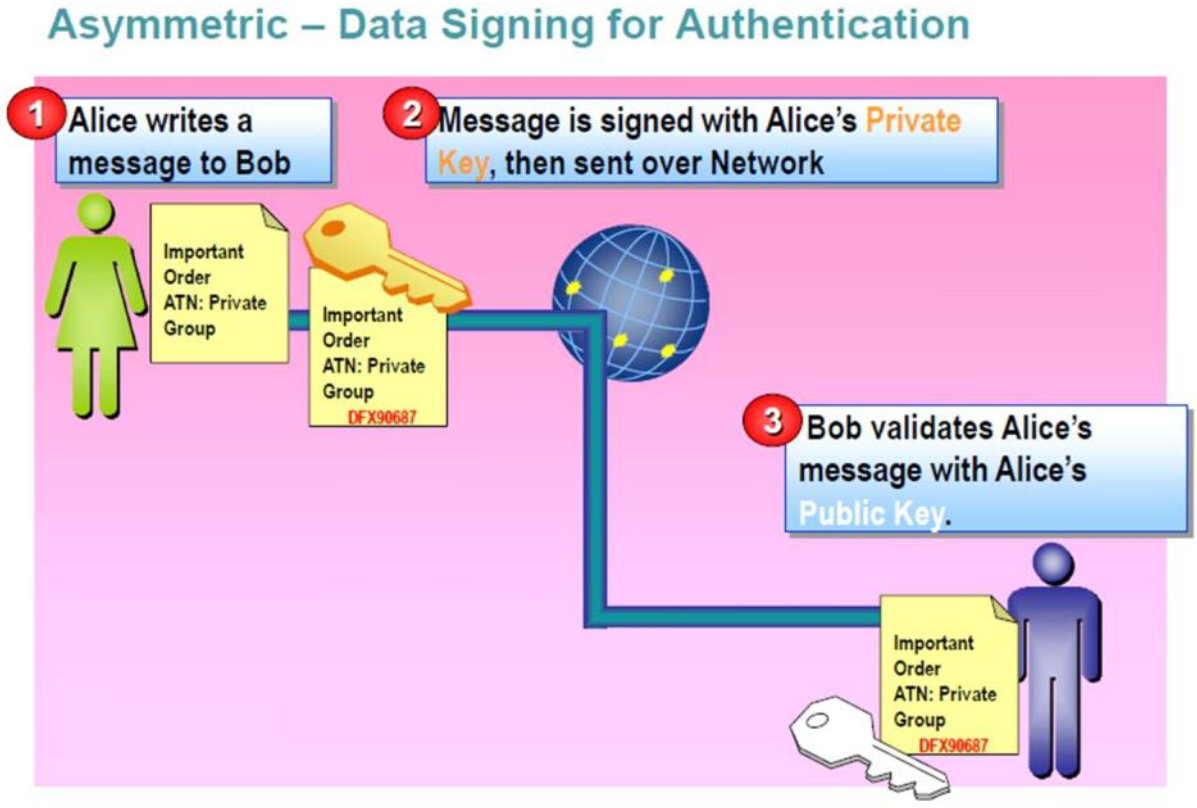
Algorithm	Key Length	Block size	Encryption Rounds
DES	56 Bits	64 Bits	16 rounds
3DES	56,112,168 Bits	64 Bits	48 rounds
AES	128,192,256 Bits	128 Bits	10,12 or 14 rounds
IDEA	128 Bits	64 Bits	8.5 rounds
Blowfish	32-448 Bits	64 Bits	16 rounds
SkipJack	80 Bits	64 Bits	32 rounds
RC	8-1024 Bits	32-128 Bits	1-18 rounds

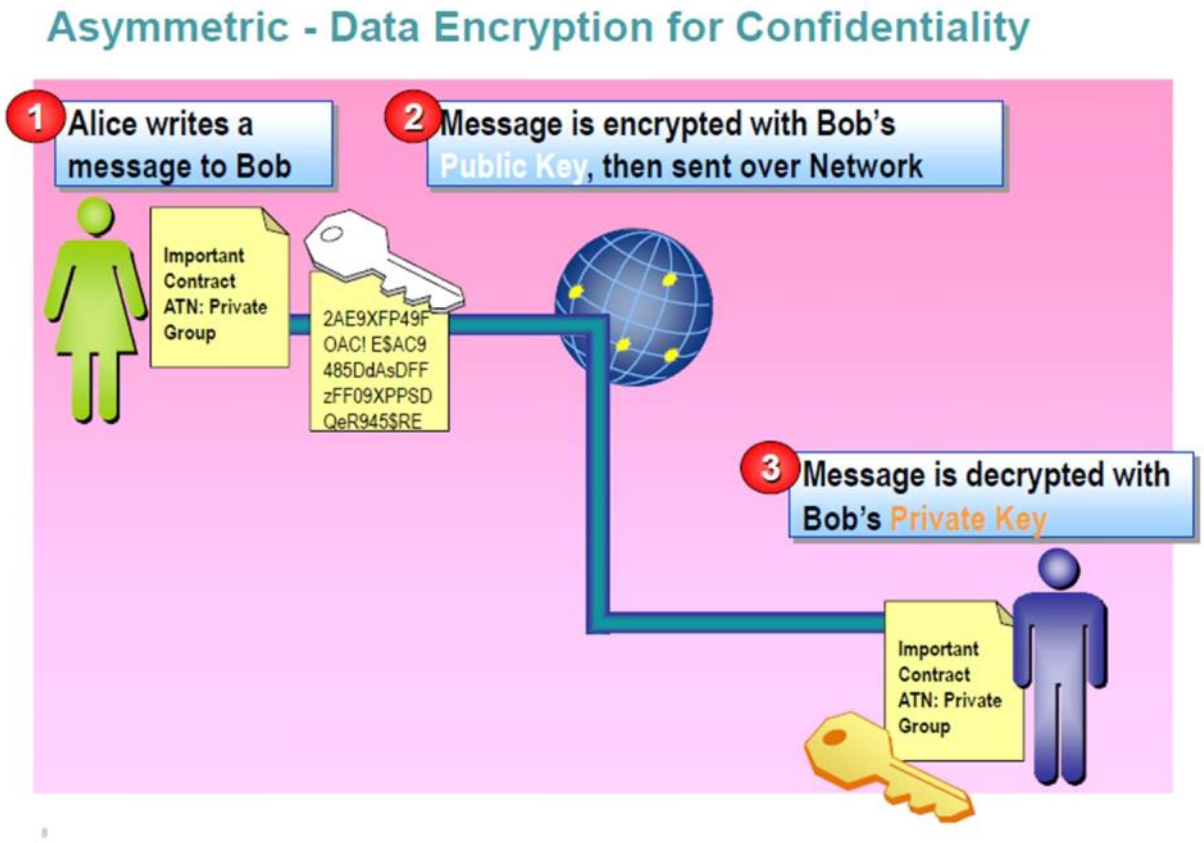
- **RC5**
  - In cryptography, RC5 is a symmetric-key block cipher notable for its simplicity.
  - Designed by Ronald Rivest in 1994, RC stands for "Rivest Cipher", or "Ron's Code" (compare RC2 and RC4).
  - The Advanced Encryption Standard (AES) candidate RC6 was based on RC5.
  - Remember RC4 is a Stream and RC5 is a Block
  - Key for RC5 can be from 0 to 2040 bits
  - Number of rounds that it executes can be adjusted from 0 to 255
  - Algorithm operates on two words at a time in a fast and secure manner.

- **Asymmetric Cryptography**
  - Asymmetric algorithms are one-way functions, that is, a process that is much simpler to go in one direction, the forward direction, than to go in the other direction, the backward direction
  - Asymmetric encryption uses two keys: **if you encrypt with one key, you may decrypt with the other**. One key may be made public (called the public key); asymmetric encryption is also called **public-key**

encryption for this reason.







- **Encryption using Receiver's Public Key ---- Confidentially**
- **Encryption using Sender's Private Key ---- Authentication**

5 Rules of Asymmetric Key Cryptography (EXAM POINT)

- When a message is encrypted with one-half of the key it must be decrypted with the other half of the key.
- Encryption with a public key provides confidentiality.
- Encryption with the sender's private key provides proof of origin - authenticity with timestamp provides nonrepudiation.
- A digital signature is created by signing a hash with a private key - it binds the document to a person nonrepudiation.
- A certificate binds a public key to an entity.

- **Different Security Goals**
  - Authenticity (Open Message Format)
    - Encrypt with Sender's Private Key.
    - No Confidentiality because anyone with a public key can decrypt confidentially.
  - Confidentially (Secure Message Format)
    - Encrypt with Receiver's Public Key
    - Only a person with a private key can decrypt
  - Authentication & Confidentiality (Secure & Sign)
    - Secure & Signed Format
    - Encrypt with sender's private key and Encrypt again with receiver's public key
- **Asymmetric Algorithm**
  - Rivest-Shamir-Adleman (RSA)
    - RSA is an asymmetric key cryptosystem that offers both encryption and digital signatures that

provide non-repudiation, integrity, and authentication of source.

- The RSA public (asymmetric) key algorithm is one of the most popular and secure (given long key lengths) encryption methods available in the asymmetric cryptography area.
- Key Size 512 ,1024 ,2048 ,4096 ,8192.
- **Exam Keys points:-** Any Questions that talk about Brute Force, Mathematical attacks, Timing attacks Ans is RSA
- **Advantages**
  - More comfortable to implement than ECC
  - Easier to understand.
  - Very fast, very simple encryption and verification.
  - Signing and decryption are similar; encryption and verification are similar.
  - Widely deployed, better industry support.
- **Disadvantages**
  - Very slow key generation.
  - Slow signing and decryption, which are slightly tricky to implement securely.
  - The two-part key is vulnerable to GCD attack if poorly implemented.

- **Diffie–Hellman key exchange (DH)**
  - Diffie-Hellman is a key negotiation algorithm and **does not provide for message confidentiality**, but is extremely useful for applications such as PKI.
  - Diffie–Hellman is based on discrete logarithm hard math problems.
  - **The Diffie–Hellman key agreement requires that both the sender and recipient of a message have their private and public key pairs**
  - Method of securely exchanging cryptographic keys over a public channel and was one of the first public-key protocols as originally conceptualized.
  - Alternative to DH is ElGamal.
- **ElGamal**
  - Double the size of data after encryption, so have preformation issue so not in use.
  - Includes the ability to **provide message confidentiality and digital signature services**, not just session key negotiation
- **Elliptic Curve Cryptography (ECC)**
  - Have the highest strength per bit of key length of any of the asymmetric algorithms
  - The ability to use a much shorter key for **ECC implementation provides saving on computational power and bandwidth**.
  - This makes ECC especially beneficial for implementations in smart cards, wireless, and other similar application areas where those elements may be lacking.
  - Advantages
    - Very fast key generation.
    - Smaller keys, cipher-texts, and signatures.
    - Fast signatures.
    - Signatures can be computed in two stages, allowing latency much lower.
    - Moderately fast encryption and decryption.
    - Than inverse throughput.
    - Right protocols for authenticated key exchange (FH-ECMQV et al.).
    - Better US government support.

- Binary curves are fast in hardware.
- Unique curves with bilinear pairings allow new-fangled crypto
- Signature generation is faster with RSA.

- Disadvantages
  - Complicated and tricky to implement securely, mainly the standard curves.
  - Standards aren't state-of-the-art, particularly ECDSA, which is a hack compared to Schnorr signatures.
  - Signing with a broken or compromised random number generator compromises the key.
  - It still has some patent problems, especially for binary curves.
  - Public key operations (e.g., signature verification, as opposed to signature generation) are slow with ECC.
  - Newer algorithms could theoretically have unknown weaknesses. Binary curves are slightly scary.

Algorithm	Key Length	Block size	Important Details
RSA	Variable (2048 Bits Recommended)	Variable (Depends on key length)	Uses 2 large prime numbers for strength
ECC	Variable (224 Bits Recommended = 2048 bits RSA)	Variable (Depends on key length)	Uses complex algebraic structure. Requires smaller key size than other algorithms
Diffie-Hellman	Variable (2048 Bits Recommended)	N/A	Requires two large numbers and discrete logarithms in a fixed field
El Gamal	Variable (2048 Bits Recommended)	N/A	Based on the Diffie-Hellman Algorithm

- **Difference between Symmetric & asymmetric-key-encryption (EXAM POINT)**

SYMMETRIC KEY ENCRYPTION	ASYMMETRIC KEY ENCRYPTION
It only requires a single key for both encryption and decryption.	It requires two keys one to encrypt and the other one to decrypt.
The size of ciphertext is same or smaller than the original plain text.	The size of ciphertext is same or larger than the original plain text.
The encryption process is very fast.	The encryption process is slow.
It is used when a large amount of data is required to transfer.	It is used to transfer a small amount of data.
It only provides confidentiality.	It provides confidentiality, authenticity, and non-repudiation.
Examples: 3DES, AES, DES, and RC4	Examples: Diffie-Hellman, ECC, El Gamal, DSA, and RSA

- **ADVANTAGES AND DISADVANTAGES OF ASYMMETRIC CRYPTOSYSTEM**

  ADVANTAGES

  - In asymmetric or public key, cryptography there is no need for exchanging keys, thus eliminating the key distribution problem.
  - The primary advantage of public-key cryptography is increased security: the private keys do not ever need to be transmitted or revealed to anyone.
  - Can provide digital signatures that can be repudiated

  DISADVANTAGES

  - A disadvantage of using public-key cryptography for encryption is speed: there are popular secret-key encryption methods that are significantly faster than any currently available public-key encryption method.

- **Advanced Encryption Standard (AES) and Elliptic Curve Cryptography (ECC) are two different things**.
  - AES is a block cipher providing a symmetric-key algorithm, while ECC is a field of cryptography (utilizing the algebraic structure of elliptic curves over finite fields) providing an asymmetric-key algorithm.
  - A strong configuration for a cryptographic protocol such as TLS might use ECC for key-exchange, AES for the cipher, and SHA-2 for message authentication.

- **Hybrid Cryptography**
  - Symmetric key is sent out-of-band distribution, an asymmetric method is used to send the key. This is called Hybrid mode.
  - Uses both asymmetrical and symmetrical encryption
    - asymmetrical for key exchange
    - symmetrical for the bulk - thus it is fast
    - example: SSL, PGP, IPSEC S/MIME
  - **Step 1 -> Symmetric Method**
    -> Sender Plaintext
    -> Shared Symmetric Session Key (Encrypt Data)
    -> Data Ciphertext
    -> Receiver receives the Data Ciphertext and Decrypts using the Shared Symmetric key received in Step 2 below.

  - Both Data and Key are sent through different channels.
  - **Step 2 -> Asymmetric Method**
    -> Shared Symmetric Session Key
    ->Receiver Public Key (Encrypt Key)
    -> Shared Key Ciphertext
    -> Receiver Private Key (Decrypt Key)
    -> Shared Symmetric Session Key

  Exam Notes

Attributes	Symmetric	Asymmetric
Keys	One key is shared between two or more	One entity has a public key, and the

	entities	other entity has a private key
Key Exchange	**Out-of-Band**	Symmetric key is encrypted and sent with a message; thus, the key is distributed by in-bound means
Speed	Algorithm is less complex and faster	Algorithm is more complex and slower
Number of keys	Grows exponentially as users grow	Grow linearly as users grow
Use	**Bulk Encryption** **This means encrypting files and communication paths**	Key encryption & Distribution keys
Security Services Provided	Confidentiality	Confidentiality Authentication & Non-Repudiation

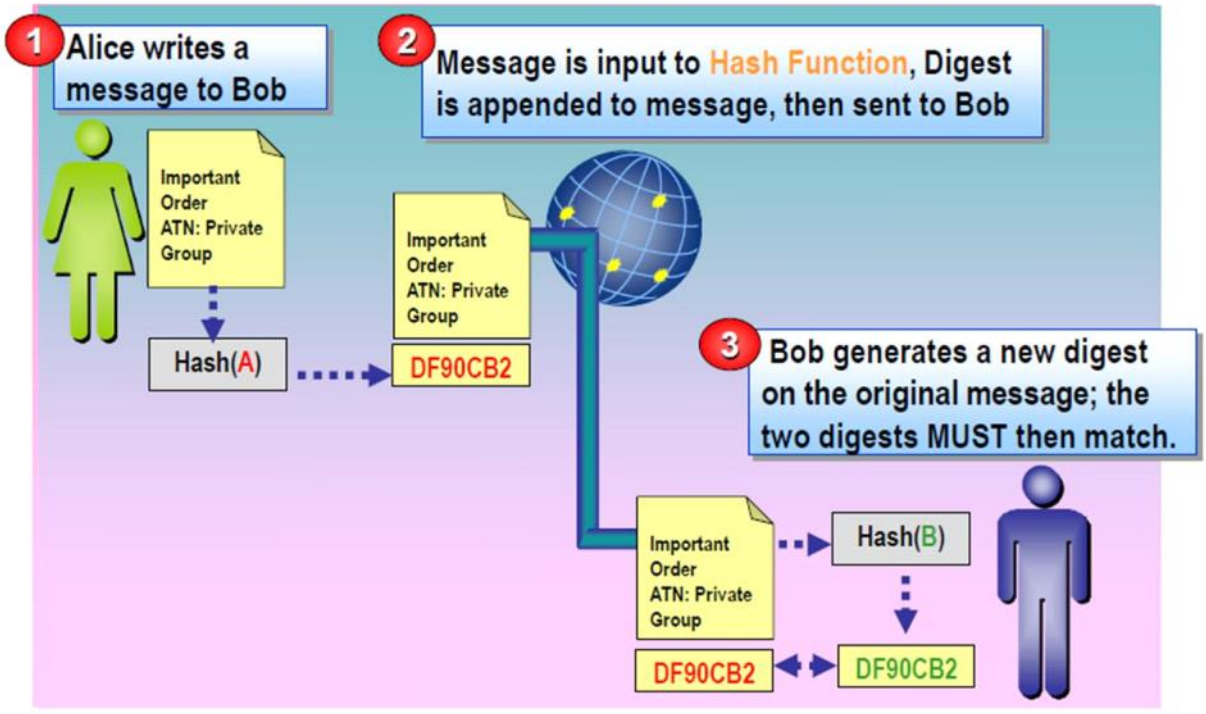
- Message Digests (Hashing)
  - Message Authentication & Integrity can be achieve using Message Digests feature only.
  - A message digest is a small representation of a larger message produced by a hashing algorithm.
  - **MD5 - 128 bit of Hash length , SHA - 160 bits of Hash length**
  - 2 different message able to produce same HASH is called HASH COLLUSION (BIRTHDAY ATTACK)
  - **Message Authentication Code (MAC)**
    - Small block of data that is generated using a secret key and then appended to the message.
    - When the message is received, the recipient can generate their own MAC using the secret key, and thereby now that the message has not changed either accidentally or intentionally in transit.
    - A common MAC implementation is Cipher Block Chaining Message Authentication Code (CBC-MAC), which uses CBC mode of a symmetric block cipher such as DES to create a MAC.
    - Message Authentication Codes provide integrity and authenticity.
  - According to RSA Security, there are five basic requirements for a cryptographic hash function
    - The input can be of any length.
    - The output has a fixed length
    - The hash function is relatively easy to compute for any input.
    - The hash function is one-way (meaning that it is extremely hard to determine the input when provided with the output).
    - The hash function is collision resistant (meaning that it is extremely hard to find two messages that produce the same hash value).

      The bottom line is that hash functions create a value that uniquely represents the data in the original message but cannot be reversed, or “de-hashed.” Access to the hashed value does not allow someone to determine what the original message actually contained. Access to both the original message and the original hashed value allows someone to verify that the message hasn’t changed since the first hash was created by generating a new hash and comparing the two. If the hashes match, the hash function was run on the same input data, so the input data has not changed.

Hash Security

- Hash collision or Birthday Attack
- There are two defenses against such attacks, neither of which was used by LinkedIn at the time:
  - Hashing complexity
  - Salting
  - Unique (calculate a new salt for every user's password, and a new salt every time the password is changed

Cryptographic Hash Function (Digest)



- **Hashed Message Authentication (HMAC)**
  - Combines a shared key with hashing.
  - Two parties must pre-share a key. Once shared, the sender uses XOR to combine the plaintext with a shared key, and then hashes the output using an algorithm such as MD5 (called HMAC-MD5) or SHA-1 (called HMAC-SHA-1). That hash is then combined with the key again, creating an HMAC.
  - The receiver combines the same plaintext with the shared key locally and then follows the same process described above, resulting in a local HMAC. The receiver compares that with the sender's HMAC. If the two HMACs matches, the sender is authenticated (this proves the sender knows the shared key), and the message's integrity is assured.

- **Quantum Cryptography**
  - Quantum cryptography, on the other hand, uses physics to secure data

- Quantum cryptography, also known as quantum key distribution, is built on quantum physics
- **Quantum cryptography is a set of protocols, systems, and procedures by which it is possible to create and distribute secret keys.**
- It is important to note that quantum cryptography is not used to encrypt data, transfer encrypted data, or store encrypted data.
- Quantum cryptography solves the key distribution problem by allowing the exchange of a cryptographic key between two remote parties with complete security, as dictated via the laws of physics
- It's faster than Asymmetric.
- Used in Fiber optic light as a frequency to exchange data, calculation they use physical than matics , faster key distribution algorithm.

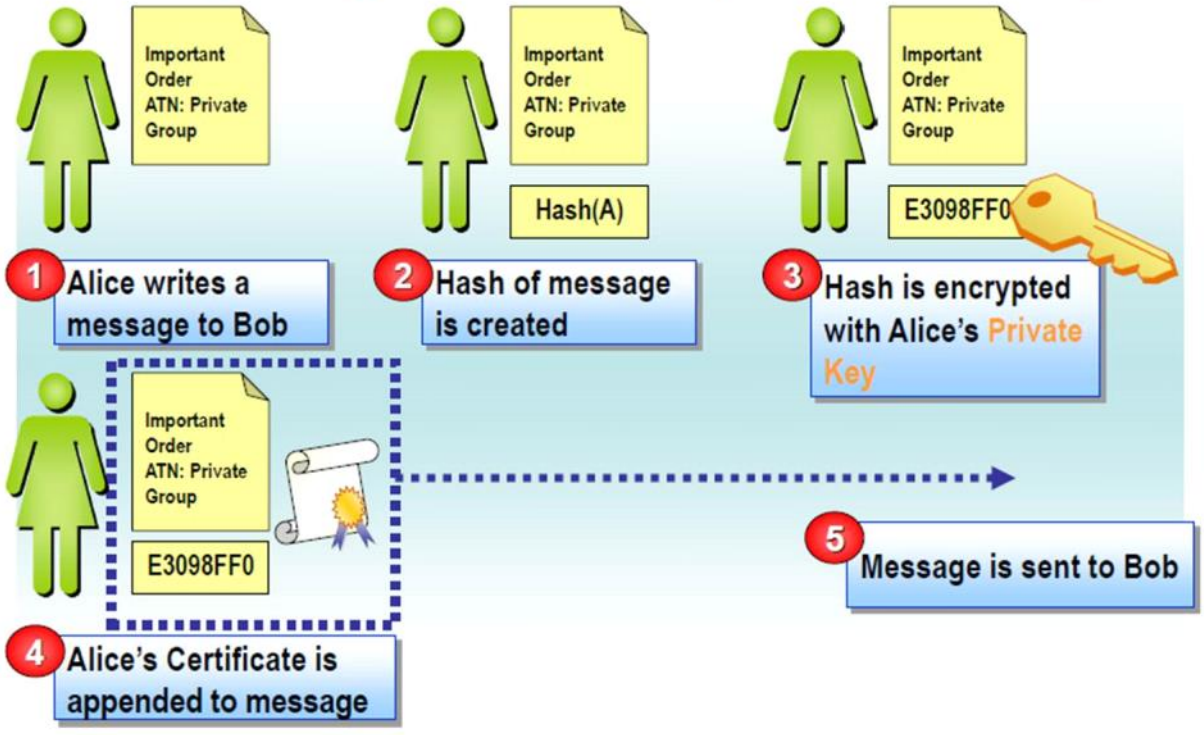
- **Digital Signature**
  - A digital signature can provide several assurances. It will assure that the message does indeed come from the person who claims to have sent it, it has not been altered, both parties have a copy of the same document, the person sending the document cannot claim they did not send it, and the person receiving it cannot claim they have received a different message
  - Digitally signed messages assure the recipient that the message truly came from the claimed sender They enforce nonrepudiation (that is, they preclude the sender from later claiming that the message is a forgery).
  - Digitally signed messages assure the recipient that the message was not altered while in transit between the sender and recipient. This protects against both malicious modification (a third party altering the meaning of the message) and unintentional modification (because of faults in the communications process, such as electrical interference).

  - Digital signature is a block of data produced by hashing the message with a hashing algorithm that produces a message digest that is generated based on the contents of the message.
  - A Digital Certificate is an electronic document that asserts authenticity & data integrity that is tied to sender.
  - **Digital Signature Non-Repudiation** Determine the information source by signing a hash or any other data with a private key. If it is possible to decrypt the information with the sender's public key, the sender has been verified, thus resulting in non-repudiation. Non-repudiation exists when the sender cannot deny his or her association with data transmission.
  - **Digital signature algorithms rely on a combination of the two major concepts already public key cryptography and hashing functions.**
    - If you want to encrypt a confidential message, use the recipient's public key.
    - If you want to decrypt a confidential message sent to you, use your private key.
  -
    - If you want to digitally sign a message you are sending to someone else, use your private key.
    - If you want to verify the signature on a message sent by someone else, use the sender's public key.

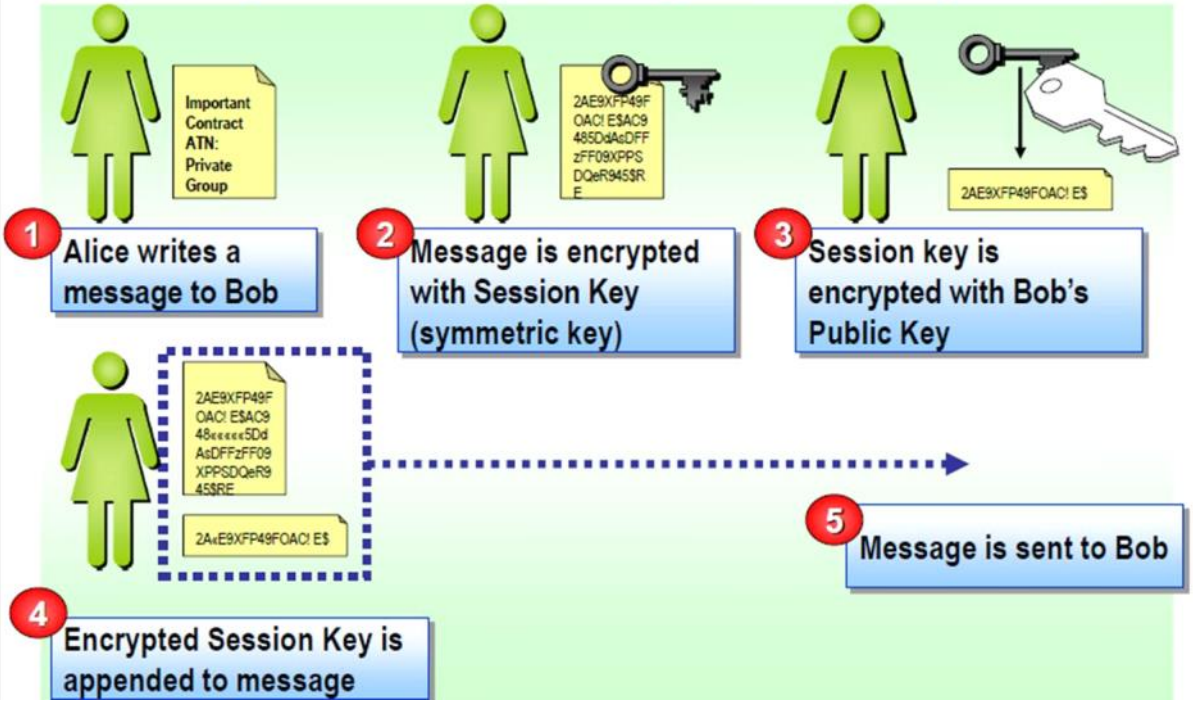
- **Public Key Cryptography (PKI)**

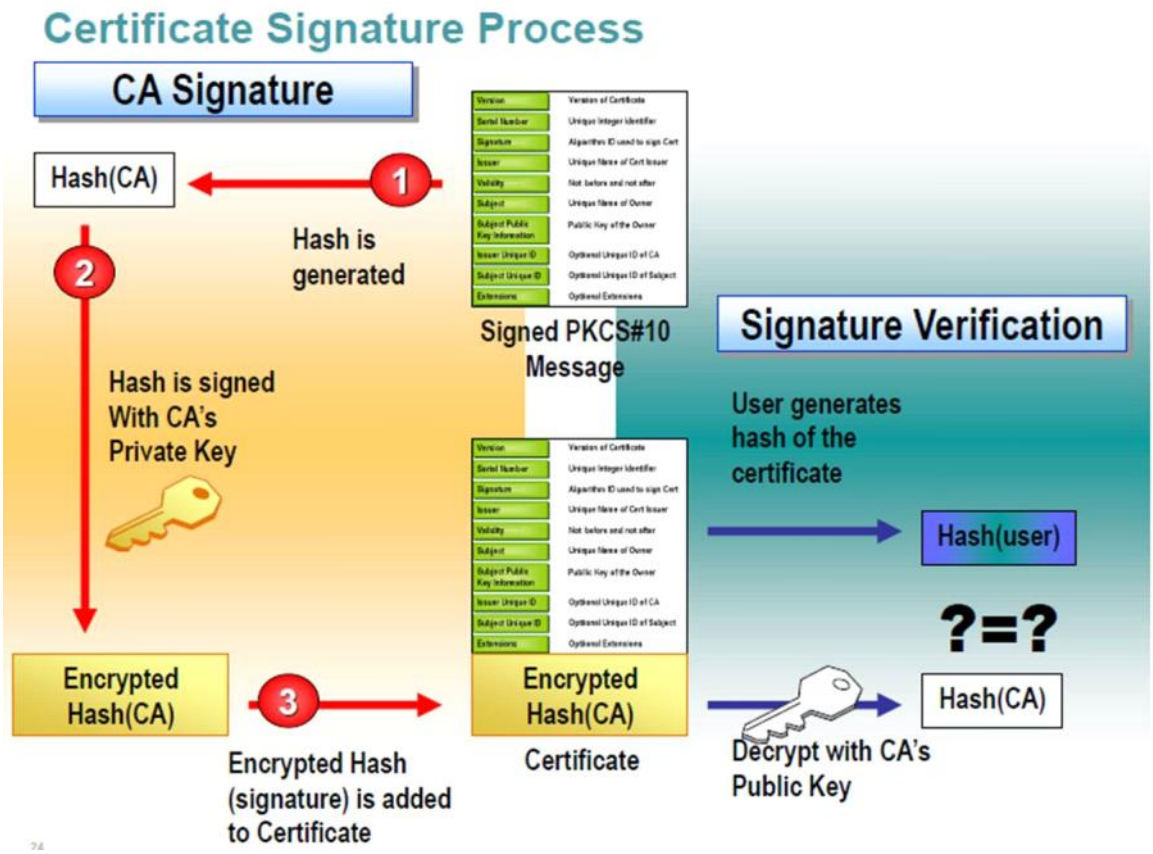
- A PKI is a set of system, software, communication, and cryptography protocols required to use, manage, and control public-key cryptography.
- It has four primary purposes:
  - Publish public keys/certificate
  - Certify that a key is tied to an individual or entity
  - Verify the validity of a public key
  - Provide security services such as confidentiality, integrity, authenticity, non-repudiation, and access control.
- PKI Certification Authority issue a certification called an X.509
  - **X.509**
    - X.509 defines a common set of information and required attributes to create a PKI certificate, also defines the requirement for a Certificate Signing Request (CSR) to be used for a CA to create a PKI Certificate.
  - **Certification/Certificate Authority (CA**)
    - The certificate authority "signs" an entity's digital certificate to certify that the certificate content accurately represents the certificate owner, including their public key.
    - Signs an entity's digital certificate to certify that the certificate content accurately represents the certificate owner.
    - **Entity/Server trusted by one or more users responsible for the issue, revoke and, manage the certificate.**
  - **Certificate Revocation (CR)**
    - If the subscriber loses control of the private key—may have been compromised—the certificate has become unreliable, and the certification authority would revoke (permanently invalidate) the certificate.
  - **Registration Authorities (RA)**
    - Accept and verify registration information.
    - Accept and authorize requests for certification revocation
    - Cannot issue a certificate
    - Offload work from CA

PKI – Digital Signature for non-repudiation - Sending



PKI for symmetric key exchange – Encrypting to Send





- **Common uses of PKI**
  - Provide user or system component identification and authentication for web communications.
  - PKI is used to sign and encrypt email messages in a variety of applications.
  - PKI is used to digitally sign important documents
  - PKI can be used to authenticate users from system access.
  - Confidentiality, access control, Integrity, Authentication, and Nonrepudiation.
  - Certificates and digital signatures are based on the X.509 Version 3 standard.

- **ÇRL (Certificate Revocation List)**
  - CRL is a signed data structure containing a time-stamped list of revoked certificates.
  - If a certificate has been revoked for some reason, it will be listed on CRL.
  - When users verify another's identity through a CA, They will check the CRL to make sure it is still valid.
  - Offline process of checking the certificate.
  - Maintained the list of an expired certificates.
  - **Primary concern is latency**.

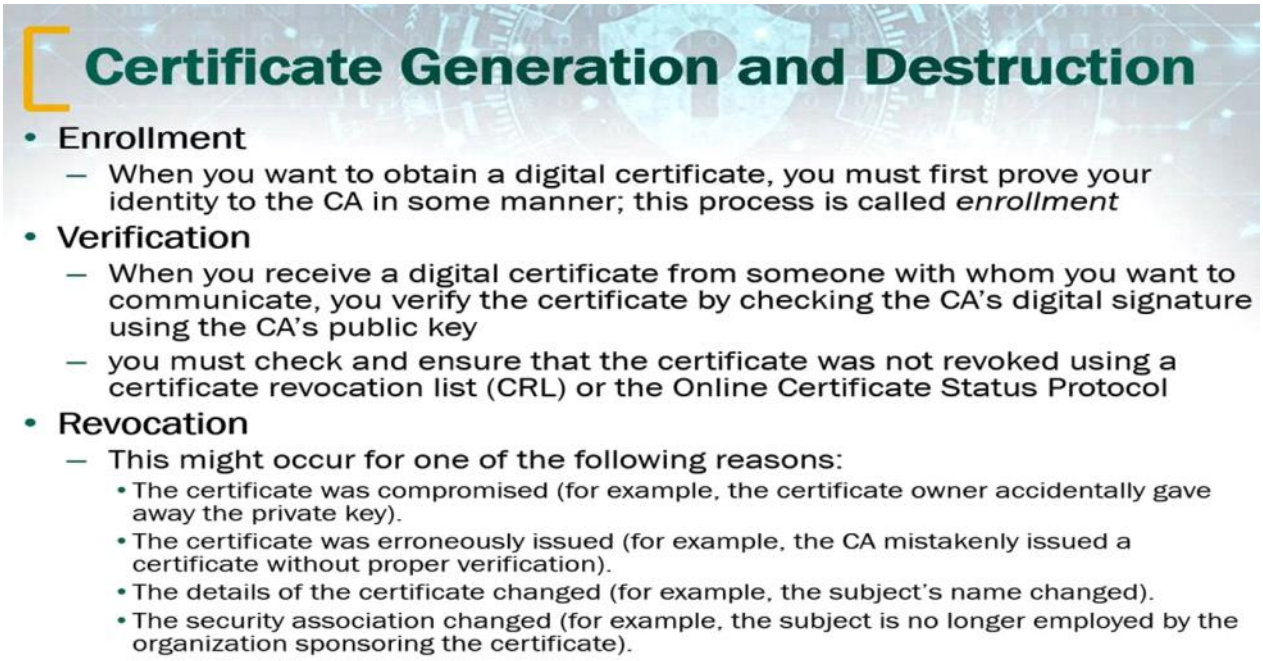
- **OCSP (Online certificate Status Protocol)**
  - An HTTP-based protocol for dynamically checking the status of the revoked certificate.
  - OCSP server accepts a request to check a certificate's status.
  - OCSP server searches the CA database by certificate's serial no.
  - OCSP server then sends the certificate's status to the requester.
  - On-line process of checking the certificate.
  - Concern with OCSP, Send all the information on unencrypted channels.
  - OCSP does not encrypt transmission by default.

- **OCSP is faster than CRL**

- **Certificate Stapling**
  - Certificate Stapling The primary issue with OCSP is that it places a significant burden on the OCSP servers operated by certificate authorities. These servers must process requests from every single visitor to a website or other user of a digital certificate, verifying that the certificate is valid and not revoked
  - Certificate stapling is an extension to the Online Certificate Status Protocol that relieves some of the burden placed on certificate authorities by the original protocol. When a user visits a website and initiates a secure connection, the website sends its certificate to the end user, who would normally then be responsible for contacting an OCSP server to verify the certificate's validity. In certificate stapling, the web server contacts the OCSP server itself and receives a signed and timestamped response from the OCSP server, which it then attaches, or staples, to the digital certificate. Then, when a user requests a secure web connection, the web server sends the certificate with the stapled OCSP response to the user. The user's browser then verifies that the certificate is authentic and also validates that the stapled OCSP response is genuine and recent. Because the CA signed the OCSP response, the user knows that it is from the certificate authority, and the timestamp provides the user with assurance that the CA recently validated the certificate. From there, communication may continue as normal

- Certificate format
  - The most common binary format is the Distinguished Encoding Rules (DER) format. DER certificates are normally stored in files with the .der, .crt, or .cer extension.
  - The Privacy Enhanced Mail (PEM) certificate format is an ASCII text version of the DER format. PEM certificates are normally stored in files with the .pem or .crt extension.

- **Important for EXAM (Sequence)**



- **Key Management**
  - **Kerckhoff's Law**
    - A Cryptosystem Should be secure even if everything about the system, except the key is public knowledge.
  - Keys should be stored and transmitted securely
  - Keys should be extremely random and use the full spectrum of a keyspace
  - Key Lifetime should correspond to the sensitivity of the data
  - Key should be properly destroyed once the lifetime ends
  - Key should not be present clear text
  - **Key Escrow** - Storing key with a trusted party. (Third Party manages the key)
  - To guard against long-term cryptanalytic attacks every key must have an expiration date.
  - Key Wrapping and Key Encrypting Keys (KEK)
    - One key is encrypted using another key, KEK is used as part of a key distribution or key exchange.
    - The process of using a KEK to protect session keys is called key wrapping, key wrapping uses symmetric

      ciphers to securely encrypt a plain text key with associated integrity information and data.
  - **Key Distribution Centers (KDC)**
    - Master key - Static key
    - Session key - Valid for the specific session, Origin of the session key comes from the master key.
  - **Key Storage and Destruction**
    - Trusted, tamper-proof hardware security modules
    - Passphrase protected by smart cards
    - Key wrapping the session keys using long term storage KEK
    - Splitting cipher keys and storing them in physically separate storage locations
    - Protecting keys using strong passwords/pass-phrases, key expire and the like
  - **Key Control**
    - **Dual Control:** Implemented as a security procedure. Two or more people are required to work in cooperation, when they come together they come with Split Knowledge specific information known

only to one individual that must be combined with knowledge held by another individual.
- **Key Escrow:** Storing key with a trusted party. It's not good practice to keep both data and key together. If a key is lost you can ask for a copy of the key from key escrow.

- **Key Attacks**
  - Brute Force
    - Every possible key is tested (online/offline)
  - Dictionary
    - List of known keys tested
  - Frequency
    - Looking for patterns to reveal the key

What makes Key Management Secure?
- Keys should be stored and transmitted by secure means
- Keys should be extremely random and use the full spectrum of the keyspace
- The key's lifetime should correspond with the sensitivity of the data it is protecting (less secure data may allow for a longer key lifetime, whereas more sensitive data might require a shorter key lifetime.
- Keys should be properly destroyed when their lifetimes end.
- Keys should not be presented in cleartext anywhere

PAIN
- **Privacy: Receiver's Public Key**
  - Encryption is used to ensure confidentiality
- **Authenticity: Sender's Private Key**
  - Digital Certificates are used for authentication
- **Integrity: (Not Asymmetric Or Symmetric)**
  - Hashing is used to prove integrity.
- **NON-Repudiation: Hash Encrypted Sender's Private Key.**
  - Digital signatures are used to provide non-repudiation

- **Attacks On Cryptosystem**
  - Intention is to break a cryptosystem and find the plaintext from the ciphertext. The attacker’s objective is to identify the key.
  - The true strength of cryptosystem is the size and secrecy of the key
  - **Kirchhoff's law** - A Cryptosystem should be secure even if everything about the system, except the key, is public knowledge.
  - Segregation of Duties: A cross-check to ensure that misuse and abuse of assets due to innocent mistake or malicious intent can be efficiently detected and prevented

Ciphertext Only Attack
- A sample of ciphertext is available without the plaintext associated with it.
- Ciphertext-only attack is one of the most difficult because the attacker has so little information with which to start
- Captured ciphertext only
- Most Common attack
- Mitigate by increase the key length

Know-Plaintext Attack

- A sample of ciphertext and the corresponding known plaintext is available.
- Known plaintext attack where the cryptanalyst finds large amounts of plaintext/ciphertext pairs created with the same key.
- 2DES is vulnerable to this attack. (Meet in the Middle Attack)

Chosen-Plaintext Attack

- Cryptanalyst can choose a quantity of plaintext and then obtain the corresponding encrypted text to try and recover the key
- An adaptive chosen-plaintext attack is where the attacker can modify the chosen input files repeatedly to see what effect that would have on the resulting ciphertext
- Can choose the plaintext to get encrypted and obtain the corresponding ciphertext.
- Attacker sends a message they think the victim will encrypt and sends out to others.

Chosen-Cipher Attack

- Can select the ciphertext and obtain the corresponding plaintext
- An adaptive chosen ciphertext would be the same, except that the attacker can repeatedly modify the ciphertext before putting it through the algorithm
- Attacker can choose the ciphertext to be decrypted and has access to the resulting decrypting plaintext.

- **Cryptanalysis**
  - Cryptanalysis is the process of reverse engineering cryptography algorithms.
  - The study of techniques for attempting to defeat cryptographic techniques and, more generally, information security services

    - **Linear Cryptanalysis -** A known-plaintext attack and uses a linear approximation to describe the behavior of the block cipher. Known plaintext attack that attempts to discover the crypto key by comparing the plain text and the ciphertext pairs that were created with the same key - The attacker will run large amounts of information through the linear cryptanalysis to increase the probability of finding the correct encryption key.

    - **Differential Cryptanalysis -** Also called a side-channel attack, this more complex attack is executed by measuring the exact execution times and power required by the crypto device to perform the encryption or decryption. By measuring this, it is possible to determine the value of the key and the algorithm used.

- **Side-Channel Attacks (IMP EXAM)**
  - Are passive attacks that rely on a physical attribute of the implementation such as **power consumption/emanation.**
  - These attributes are studied to determine the secret key and the algorithm function. Some examples of popular side-channels include timing analysis and electromagnetic differential analysis.
  - A side-channel attack gathers information regarding the physical resource consumption, timing, and more during the encryption and decryption process.
  - **Cool Boot attack**-type of Side-Channel attacks

- **Statistical attacks**

- A Statistical attack focuses on the flaws in the statistical patterns of the algorithm
- Statistical attack targets the design of the cryptographic algorithm such as floating-point errors and the inability to create true Ramon numbers
- Finding these flaws can statistically reduce the amount of time it takes to find the cryptographic

- **Reply Attack**
  - This attack is meant to disrupt and damage processing by the attacker, through the resending of repeated files or input to the host.
  - If there are no checks such as time-stamping, use of one-time tokens, or sequence verification codes in the receiving software, the system might process the duplicate file.

❖ For questions and more clarity refer Cryptography Simple Link

❖ For questions and more clarity refer Cryptography Coffee Dose Link

Exam Points

Question	Answer
savings on computational power and bandwidth	ECC
Encrypt with sender's private key	Authenticity / POF
Encrypt with receiver's public key	Confidentiality
Which one Secure Hashing Algorithm SHA OR MD 5 ?	SHA
Ipsec work on which layer	Layer 3
CA Issues RA does ? OCSP or CRL which one is faster	Certificate Offload work of CA OCSP
Why we prefer AES over DES ?	processing overhead and the ability to work with software

- message can be encrypted, which provides **confidentiality**
- message can be hashed, which provides **integrity**
- message can be digitally signed, which provides **authentication**, **nonrepudiation**, and **integrity**.
- message can be encrypted and digitally signed, which provides **confidentiality**, **authentication**, **nonrepudiation**, and **integrity**.
- **Timestamps** and **sequence numbers** are two countermeasures to replay attacks.
- attacker could measure **power consumption**, **radiation emissions**, and the time it takes for certain types of data processing = Side Channel
- **Keyspace** A range of possible values used to form keys
- **Cryptanalysis** Practice of checking flaws within cryptosystems
- A secret key or session is symmetric key only